



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-50262 Xorg-x11-server: xorg-x11-server-xwayland: xorg-x11-server: out-of-bounds read/write in glx changedrawableattributes

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-13
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-50262 Xorg-x11-server: xorg-x11-server-xwayland: xorg-x11-server: out-of-bounds read/write in glx changedrawableattributes - Vulnerability Report

Published: 2026-06-13 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CVE-2026-50262 X.Org X Server / Xwayland GLX

ChangeDrawableAttributes out-of-bounds read/write

1. Executive Summary

CVE-2026-50262 is a medium-severity memory-safety flaw in the X.Org X server and Xwayland GLX request handler `__glXDisp_ChangeDrawableAttributes()`. Upstream analysis shows the bug is caused by a reversed request-length validation check that allows an undersized request to claim more attribute pairs than are actually present, causing the server to read past the supplied request buffer. In the default case this supports information disclosure; in a narrower path it can also lead to an out-of-bounds write when over-read data is interpreted as a `GLX_EVENT_MASK` attribute and copied into server state.

From a defender perspective, this is not a broad internet-scale edge vulnerability. The reviewed sources consistently describe a local X11/GLX attack path: the adversary must already be able to execute a client that can talk to the target X server or Xwayland instance. That keeps the risk concentrated in Linux desktops, kiosks, thin-client or VDI estates, lab systems, and multi-user UNIX environments where low-privilege users can launch code locally or pivot into another user's graphical session.

The highest-risk environments are legacy or specialized deployments that still run Xorg with elevated privileges, or that have configuration drift enabling byte-swapped clients. Upstream explicitly notes that the write path requires byte-swapped clients, which are disabled by default in modern X server configurations. Even when privilege escalation is not realistic, the flaw still creates practical risk through local information disclosure and potential display-server instability or crash conditions.

Immediate defender priorities are straightforward: patch to upstream-fixed versions or vendor-backported builds, inventory systems that expose X.Org X server or Xwayland to untrusted local users, and add monitoring for abnormal Xorg/Xwayland crashes, suspicious local X11 client activity, and configuration drift that re-enables older protocol behaviors. Because public technical details and the patch are already available, organizations should treat this as a near-term hardening task rather than a purely theoretical issue.

2. Intelligence Requirement

This report addresses the following intelligence requirement: what does CVE-2026-50262 mean for defenders operating Linux endpoints and shared graphical infrastructure, which environments are materially exposed, what conditions increase impact, and what remediation, detection, and hunting actions should be prioritized?

Question	Assessment
What is the flaw?	A reversed size check in <code>__glXDisp_ChangeDrawableAttributes()</code> and its byte-swapped variant allows an undersized GLX request to pass validation and be processed as if it contained more attribute pairs than were actually supplied.
Is remote exploitation the primary concern?	No. The reviewed sources describe a client-to-X-server request path, making this primarily a local or already-adjacent attack against reachable X11/GLX sessions rather than a default internet-facing service issue.
What is the likely impact?	Information disclosure is the primary default impact. A constrained out-of-bounds write path also exists; upstream notes that this path requires byte-swapped clients, which are disabled by default. Crash or session instability is also plausible.
Which versions are fixed upstream?	<code>xorg-server</code> 21.1.23 and <code>xwayland</code> 24.1.12.
Which environments deserve the most attention?	Shared Linux workstations, VDI/kiosk deployments, build/test systems with GUI components, and any rootful Xorg estate or non-

	default configuration that broadens X11 attack surface.
Is public exploitation confirmed?	No reviewed primary source asserted in-the-wild exploitation at the time of writing. Public patch and advisory detail reduce attacker development effort, but this report found no authoritative confirmation of active campaigns.

3. Source Review and Confidence

Source	Contribution	Confidence
X.Org security advisory	Canonical disclosure, affected components, fixed versions, and the important caveat that the write path requires byte-swapped clients disabled by default	High
Upstream X.Org patch commit	Concrete root cause, exact faulty comparison, exploit mechanics, and regression history tied to legacy Mesa compatibility code	High
Debian Security Tracker	Downstream package exposure, fixed package versions, and distro notes that Xwayland risk is lower where it is not expected to run as root	High
Ubuntu CVE page	Severity, CVSS breakdown, distro package status, and packaging notes for `xorg-server` and `xwayland`	High
Red Hat Bugzilla / CNA record	Product naming, summary, and vendor severity classification (`medium`)	High
Microsoft Security Update Guide intake item	Discovery and workflow trigger only; not treated as the authoritative technical source for Linux package impact	Medium

Assessment confidence is high for the core technical narrative because the upstream advisory and patch are explicit about both the bug class and the fixed versions. Confidence is medium for ecosystem-wide exploitation likelihood because the public record reviewed here did not include mature proof-of-exploit weaponization or incident telemetry, and real-world impact varies substantially with local X11 exposure, privilege model, and distro hardening.

Two caveats matter operationally. First, upstream version numbers are necessary but not sufficient for patch management because many enterprise Linux vendors backport fixes without matching upstream release strings. Second, the most serious integrity or privilege-escalation narratives are conditional rather than universal: they depend on rootful Xorg deployments, permissive local access, or protocol behavior such as byte-swapped client handling that is disabled by default in many environments.

4.1 Vulnerability metadata

Field	Value
CVE	CVE-2026-50262
Product family	X.Org X server and Xwayland
Vulnerable function	<code>__glXDisp_ChangeDrawableAttributes()</code> /

	`__glXDispSwap_ChangeDrawableAttributes()`
Weakness	Improper request-length validation causing out-of-bounds read with constrained write side effect
Ubuntu CVSS v3.0	5.5 / Medium
Ubuntu vector	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Ubuntu confidentiality / integrity / availability	High / None / None
Red Hat severity	Medium
Upstream fixed versions	`xorg-server` 21.1.23; `xwayland` 24.1.12
Public disclosure date	2026-06-04 (X.Org CVE assignment follow-up to June security advisory)
CVE publication date seen in downstream trackers	2026-06-05
Primary default impact	Local information disclosure
Conditional impact	Crash/instability and constrained write path; privilege escalation is environment-dependent and materially more concerning where Xorg still runs as root

4.2 Flaw mechanics

The upstream patch shows that the bug is not a generic parser issue but a specific validation regression in GLX request handling. The vulnerable code checked whether the computed request size was less than `client->req_len`` when it should have rejected requests where the computed size was greater than the actual supplied length. As a result, an undersized request could advertise a larger `numAttribs`` value than the request body really contained and still pass the length check.

Once that validation fails open, `DoChangeDrawableAttributes()` iterates over attribute pairs starting immediately after the request header. Because the request does not actually contain as many pairs as claimed, the server reads beyond the real request buffer into adjacent memory. The patch notes that this becomes an out-of-bounds write when the over-read data happens to contain the `GLX_EVENT_MASK`` key and its adjacent value is written into `pGlxDraw->eventMask``.

The upstream fix replaced the broken comparison with `REQUEST_FIXED_SIZE(...)``, restoring strict length validation for both normal and byte-swapped request handlers. The patch also ties the issue back to historical compatibility code introduced to work around incorrect Mesa request lengths, noting that the Mesa-side problem had already been fixed in 2011. That history matters defensively because it shows how legacy protocol exceptions can preserve vulnerability surface long after the original interoperability issue is gone.

4.3 Affected products and exposure profile

Exposure pattern	Why it matters	Priority
Shared Linux desktops and jump hosts	Untrusted or low-privilege users may already have the ability to launch local clients against a graphical session, making local information disclosure materially relevant	High
Rootful Xorg deployments	Any memory-safety flaw in a root-running display server raises the ceiling from session-level impact toward local privilege escalation	High

Modern rootless Xwayland on managed desktops	Default hardening and non-root execution reduce the worst-case path, but information disclosure and user-session disruption remain possible	Medium
Kiosk, OT HMI, and thin-client estates	A crash or unstable display server can have disproportionate operational impact even without privilege escalation	Medium
Internet-exposed X11/TCP legacy services	Not required for exploitation, but any residual network-reachable X11 service broadens who can reach the vulnerable parser	Medium

4.4 Downstream package observations

Debian tracking shows `xorg-server` fixed in unstable at `2:21.1.23-1` and `xwayland` fixed in `forky, sid` at `2:24.1.12-1`, while multiple older Debian release lines remained vulnerable when checked. Ubuntu rated the issue Medium with CVSS 5.5 and showed package status as needs evaluation across current supported releases at review time. Debian's notes additionally state that some `xwayland` cases are treated as lower concern because Xwayland should not be running as root, reinforcing the importance of privilege model when prioritizing remediation.

5.1 Exploitation status and attacker utility

No reviewed primary source asserted confirmed in-the-wild exploitation. However, the public advisory, vendor trackers, and patch diff provide enough detail for a capable local attacker to reproduce the vulnerable request path without needing proprietary research. That places the CVE in a common post-disclosure risk category: low-value for indiscriminate internet exploitation, but useful for local privilege escalation chains, multi-user workstation abuse, insider activity, container/desktop escape research, or red-team tradecraft in Linux-heavy estates.

5.2 Realistic attack scenarios

- A low-privilege user on a shared Linux workstation crafts a malformed GLX request to a local X.Org session to read beyond request boundaries and harvest residual process memory, session data, or nearby protocol material.
- An operator or attacker with code execution inside a kiosk, lab, or thin-client environment leverages the flaw to crash the display server, creating user disruption or forcing a session reset during another operation.
- In a legacy rootful Xorg environment, an adversary explores the constrained write behavior and adjacent memory effects as part of a broader local privilege-escalation chain.
- In environments with residual X11/TCP exposure or permissive `xhost`-style trust, an attacker who gains network adjacency to the display service could transform what is normally a local-only flaw into a reachable lateral-movement opportunity.

5.3 MITRE ATT&CK mapping

ATT&CK mapping is necessarily conditional because this CVE is a vulnerability rather than a malware family or stable intrusion set. The following mappings are the most defensible based on reviewed source material.

ATT&CK ID	Technique	Rationale
T1068	Exploitation for Privilege Escalation	Applicable where Xorg runs with elevated privileges and the flaw is used to move from local code execution toward higher privileges.
T1005	Data from Local System	The default impact is information disclosure from process memory beyond the request boundary, which can support local data access objectives.

T1499	Endpoint Denial of Service	Relevant where malformed requests are used primarily to destabilize or crash X.Org / Xwayland sessions.
-------	----------------------------	---

6.1 Detection strategy summary

Signal	Telemetry source	Analytic goal	Coverage caveat
`Xorg` / `Xwayland` segfault, crash, or abnormal restart	journald, syslog, kernel logs, EDR process telemetry	Detect failed exploitation, stability impact, or suspicious local testing	High-fidelity for crash outcomes, low coverage for successful read-only activity
Unexpected local clients interacting with X11 sockets	auditd, eBPF, EDR process/file/socket telemetry	Identify unusual processes touching `/tmp/.X11-unix/` or abstract X11 sockets from non-interactive contexts	Requires Linux host telemetry that many orgs do not yet collect
Configuration drift enabling risky protocol modes	process command line, config management, package baselines	Prioritize hosts where rootful Xorg or byte-swapped-client support increases consequence	More useful for exposure reduction than for alerting
Sudden GLX-related faults after package upgrade lag	package inventory plus logs	Correlate vulnerable versions with runtime instability or suspicious local activity	Depends on accurate asset/package inventory

6.2 Sigma - X.Org / Xwayland crash indicators

```

title: Linux X.Org or Xwayland Crash Potentially Related to GLX Abuse
id: 8d2e4286-7cb3-4a7c-8df4-0f660f36c262
status: experimental
description: Detects syslog or journald-style crash indicators involving Xorg or Xwayland that may warrant review for malformed GLX request abuse, including CVE-2026-50262.
author: Lost Boys Cyber
date: 2026-06-13
references:
  - https://lists.x.org/archives/xorg-announce/2026-June/003705.html
  - https://gitlab.freedesktop.org/xorg/xserver/-/commit/6d459e4daf715bea8abdafa8fb130be2f8a1d145
logsource:
  product: linux
  service: syslog

detection:
  proc:
    Message|contains:
      - 'Xorg'
      - 'Xwayland'
  fault:
    Message|contains:
      - 'segfault'
      - 'general protection fault'
      - 'core dumped'
      - '__glXDisp_ChangeDrawableAttributes'
      - 'glx'
  condition: proc and fault
falsepositives:
  - Benign graphics stack crashes after driver upgrades or hardware instability
  - General X11/Wayland troubleshooting activity by administrators
level: medium
tags:
  - attack.t1068
  - attack.t1499

```

6.3 KQL - Linux crash and suspicious X11 activity hunt

```

let lookback = 14d;
let x11CrashSignals = Syslog
| where TimeGenerated > ago(lookback)
| where ProcessName in~ ("Xorg", "Xwayland", "kernel", "systemd-coredump")
| where SyslogMessage has_any ("segfault", "general protection fault", "core dumped",
"__glXDisp_ChangeDrawableAttributes", "glx")
| project TimeGenerated, Computer, ProcessName, Facility, SeverityLevel, SyslogMessage;
let x11SocketTouches = DeviceFileEvents
| where Timestamp > ago(lookback)
| where FolderPath has "/tmp/.X11-unix"
| project Timestamp, DeviceName, InitiatingProcessAccountName, InitiatingProcessFileName,
InitiatingProcessCommandLine, FolderPath, ActionType;
x11CrashSignals
| join kind=leftouter (
    x11SocketTouches
    | extend Computer = DeviceName, TimeGenerated = Timestamp
) on Computer
| order by TimeGenerated desc

```

6.4 Splunk - crash triage query

```

(index=syslog OR index=os_linux OR index=edr_linux)
("Xorg" OR "Xwayland")
("segfault" OR "general protection fault" OR "core dumped" OR "__glXDisp_ChangeDrawableAttributes" OR
"glx")
| stats earliest(_time) as first_seen latest(_time) as last_seen count by host process_name message
| convert ctime(first_seen) ctime(last_seen)

```

6.5 Threat-hunting hypotheses

Hypothesis	Why it matters	Data needed
A non-interactive or service-owned process is touching X11 sockets on Linux endpoints	This can indicate abuse of local graphical IPC from an unexpected execution context	auditd/eBPF socket telemetry, file access telemetry for `/tmp/.X11-unix/`, EDR process lineage
Xorg/Xwayland crashes cluster on unpatched hosts after suspicious local process execution	Failed exploit development or stability testing may manifest as repeated local crashes	package inventory, journald/syslog, EDR process telemetry
Hosts with rootful Xorg or stale X11/TCP exposure overlap with high-value user populations	Those systems amplify the consequence of a local parser flaw	asset inventory, process command lines, service configs, exposure scanning

6.6 Hunt query - suspicious X11 socket access by atypical processes

```

DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has "/tmp/.X11-unix"
| where InitiatingProcessFileName !in~ ("Xorg", "Xwayland", "gnome-shell", "plasmashell", "Xwayland")
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Count=count() by DeviceName,
InitiatingProcessAccountName, InitiatingProcessFileName, InitiatingProcessCommandLine, FolderPath
| order by Count desc

```

7. Recommendations

Priority	Owner	Action	Rationale
High	Endpoint / Linux engineering	Patch to vendor-fixed or vendor-backported builds corresponding to upstream `xorg-server` 21.1.23 and	Version-based remediation is the most reliable control for this parser flaw

		`xwayland` 24.1.12	
High	Asset management	Inventory systems running X.Org X server, Xwayland, or legacy X11/TCP listeners, and distinguish rootful from rootless deployments	Exposure and consequence vary sharply by deployment model
High	Desktop / platform engineering	Eliminate or tightly restrict rootful Xorg where business requirements permit	This reduces the worst-case privilege-escalation narrative
Medium	Detection engineering	Add monitoring for Xorg/Xwayland segfaults, core dumps, and unusual local X11 socket access	Local exploitation and failed testing are more likely to surface through host telemetry than network controls
Medium	Configuration management	Audit for non-default support of byte-swapped clients, permissive `xhost` configurations, and unintended X11/TCP exposure	These drifts can broaden reachability or consequence beyond modern defaults
Medium	SOC / threat hunting	Hunt for repeated Xorg/Xwayland instability on systems that also show local developer tooling, exploit-framework usage, or anomalous GUI access from service accounts	This helps distinguish benign graphics crashes from potentially malicious activity
Low	Security architecture	Prioritize Wayland-first and rootless display architectures during platform refresh cycles	Long-term surface reduction lowers the impact of legacy X11 parser issues

No stable network or file indicators of compromise were identified from the reviewed sources. Defenders should treat this as a vulnerability-management and host-behavior detection problem, not as an IOC-driven detection case.

8. References

- 1. X.Org Security Advisory: multiple security issues X.Org X server and Xwayland (includes CVE assignment update for CVE-2026-50262) - <https://lists.x.org/archives/xorg-announce/2026-June/003705.html>
- 2. X.Org xserver patch: `glx: fix reversed length check in ChangeDrawableAttributes` - <https://gitlab.freedesktop.org/xorg/xserver/-/commit/6d459e4daf715bea8abdafa8fb130be2f8a1d145>
- 3. Debian Security Tracker - CVE-2026-50262 - <https://security-tracker.debian.org/tracker/CVE-2026-50262>
- 4. Ubuntu CVE page - CVE-2026-50262 - <https://ubuntu.com/security/CVE-2026-50262>
- 5. Red Hat Bugzilla / CNA record 2485387 - https://bugzilla.redhat.com/show_bug.cgi?id=2485387
- 6. Microsoft Security Update Guide intake item - <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-50262>